

VULNERABILITY ASSESSMENT & PENETRATION TESTING (VAPT) REPORT

Target Environment: Multi-Platform Virtual Security Laboratory

- Standard Reference: NIST Special Publication 800-115
- Document ID: VAPT-NIST-01
- Assessment Model: Remote Black-box network Assessment
- Assessment Date: September 11, 2026
- Assessor: Kamalpreet Singh
- Classification: Lab Assessment Artifact

SECTION 1: ASSESSMENT SCOPE & TARGET IDENTIFICATION

1.1 Rules of Engagement & Authorization

This assessment is conducted within a strictly isolated, private virtual machine network under explicit testing rules of engagement. All active scanning, service interrogation, and vulnerability detection routines were restricted to the allocated CIDR block to prevent operational degradation or out-of-scope interactions.

1.2 System & Network Specifications

The engagement evaluated two distinct target endpoints from a single dedicated security evaluation node:

- **Assessor Testing Node:**
 - Hostname: Kali Linux 64-bit (kernel6.x)
 - Testing IP Address: 192.168.64.129
 - Role: Originator for active Host Discovery, Service Fingerprinting, and Vulnerability Scanning
- **Target Node 1 (Linux Ecosystem):**
 - System: Metasploitable Linux (Ubuntu Linux 8.04 baseline)
 - Target IP Address: 192.168.64.133
 - Scope Classification: Legacy Unhardened Daemon Environment
- **Target Node 2 (Windows Ecosystem):**
 - System: Microsoft Windows Server 2022
 - Target IP Address: 192.168.64.130
 - Scope Classification: Modern hardened Enterprise Server Baseline

```
(red@Kali)-[~]
$ free -h
              total        used        free      shared  buff/cache   available
Mem:           3.7Gi        1.1Gi        1.7Gi         24Mi        1.2Gi        2.7Gi
Swap:           2.0Gi          0B         2.0Gi
```

```
(red@Kali)-[~]
$ df -h
Filesystem      Size  Used Avail Use% Mounted on
udev            1.8G   0    1.8G   0% /dev
tmpfs           384M   1.2M 383M   1% /run
/dev/sda1       47G   21G   24G   47% /
tmpfs           1.9G   4.0K 1.9G   1% /dev/shm
none            1.0M   0    1.0M   0% /run/credentials/systemd-journald.service
tmpfs           1.9G   8.0K 1.9G   1% /tmp
none            1.0M   0    1.0M   0% /run/credentials/systemd-networkd.service
none            1.0M   0    1.0M   0% /run/credentials/getty@tty1.service
tmpfs           384M  108K 384M   1% /run/user/1000
```

SECTION 2: NIST SP 800-115 METHODOLOGY EXECUTION

The Testing workflow adhered to the technical testing phases defined in NIST Special Publication 800-115:

1. **Planning:** Target scoping, rules of engagement verification, and testing platform readiness (storage, database dependencies, and service checks).
2. **Discovery:** Host identification, port scanning, and service/OS fingerprinting utilizing Nmap.
3. **Attack (Vulnerability Validation):** Automated vulnerability scanning, daemon interrogation, and flaw verification via the Greenbone Vulnerability Management (GVM/OpenVAS) engine.
4. **Reporting:** Risk analysis, CVSS v3.1 scoring, comparative posture evaluation, and prioritized remediation planning.

2.1 Phase 1: Planning, Resource Verification & Tooling Setup (GVM/OpenVAS)

Prior to network transmission, system hardware, runtime engines, and database dependencies were validated on the Kali testing node.

2.1.1 Pre-Flight Hardware & Resource Auditing

- **Memory Allocation Audit:**
 - **Command Use:** free -h
 - **Observed State:** Verified 3.7 GiB Total RAM, 1.1 GiB used, 1.7 GiB free, and 2.7 Gib available headroom, supported by a 2.0 GiB swap allocation to prevent database memory exhaustion.

```
(red@Kali)-[~]
$ free -h
              total        used        free      shared  buff/cache   available
Mem:          3.7Gi        1.1Gi        1.7Gi        24Mi        1.2Gi        2.7Gi
Swap:          2.0Gi          0B        2.0Gi
```

Terminal output of free -h establishing baseline memory headroom.

- **Storage Allocation & Volume Expansion**

- **Command Use:** df -h
- **Observed State:** Primary root volume /dev/sda1 confirmed 47 GiB total capacity, 21 GiB used, and 24 GiB available capacity (47% utilization) prior to expanding the virtual disk to 100 GB to house unpacked NVT signatures and relational indexes.

```
(red@Kali)-[~]
$ df -h
Filesystem      Size  Used Avail Use% Mounted on
udev            1.8G   0    1.8G   0% /dev
tmpfs           384M  1.2M  383M   1% /run
/dev/sda1        47G   21G   24G  47% /
tmpfs           1.9G  4.0K   1.9G   1% /dev/shm
none            1.0M   0    1.0M   0% /run/credentials/systemd-journald.service
tmpfs           1.9G  8.0K   1.9G   1% /tmp
none            1.0M   0    1.0M   0% /run/credentials/systemd-networkd.service
none            1.0M   0    1.0M   0% /run/credentials/getty@tty1.service
tmpfs           384M  108K  384M   1% /run/user/1000
```

Terminal output of df -h auditing available partition storage before feed synchronization.

- **Storage Partition Auditing Prior to Disk Expansion:**

- **Command use:** lsblk
- **Observed state:** The physical virtual disk /dev/sda was sized to 100G, while /dev/sda1 was restricted to 48G, leaving unallocated capacity and an extended partition containing swap at /dev/sda5.

```
(red@Kali)-[~]
$ lsblk
NAME MAJ:MIN RM  SIZE RO  TYPE MOUNTPOINTS
sda   8:0    0  100G  0   disk
├─sda1 8:1    0   48G  0   part /
├─sda2 8:2    0    1K  0   part
└─sda5 8:5    0    2G  0   part [SWAP]
sr0   11:0   1 1024M  0   rom
```

Terminal output of lsblk displaying unallocated disk space on disk /dev/sda prior to partition growth.

- **Storage Partition Reallocation & Filesystem Resizing:**
 - **Command use:** `sudo swapoff -v /dev/sda5` , `sudo growpart /dev/sda 1`, `sudo resize2fs /dev/sda1`
 - **Technical Execution:** The swap partition residing at `/dev/sda5` was disabled via `swapoff` to clear contiguous block boundaries. The `growpart` utility dynamically expanded partition 1 across the disk boundary, and `resize2fs` committed the added storage to the active ext4 filesystem online.
- **Online Partition Expansion Verification:**
 - **Command use:** `lsblk`
 - **Observed state:** Following partition expansion via `growpart` and filesystem extension via `resize2fs`, root partition `/dev/sda1` successfully claimed the entire 100G disk allocation.

```
(red@Kali)-[~]
$ lsblk
```

NAME	MAJ:MIN	RM	SIZE	RO	TYPE	MOUNTPOINTS
da	8:0	0	100G	0	disk	
sda1	8:1	0	100G	0	part	/
r0	11:0	1	1024M	0	rom	

Terminal output of `lsblk` confirming root partition `/dev/sda1` expanded to 100G online.

2.1.2 Database Diagnostics & Dependency Remediation

- **PostgreSQL Service Verification:**
 - **Command use:** `systemctl status postgresql`
 - **Diagnostic Output:** The service was reported as Loaded: loaded, Active: inactive (dead), and present: disabled.

```
(red@Kali)-[~]
$ systemctl status postgresql
o postgresql.service - PostgreSQL RDBMS
   Loaded: loaded (/usr/lib/systemd/system/postgresql.service; disabled; preset: disabled)
   Active: inactive (dead)
```

Terminal audit revealing inactive PostgreSQL service status.

- **Starting the Relational Engine:**
 - **Command use:** `sudo systemctl start postgresql`
 - The database engine was activated to support `gvmd` transactions.

```
(red@Kali)-[~]
$ sudo systemctl start postgresql
[sudo] password for red:
```

Bringing the PostgreSQL relational database management daemon online.

- **GVM Automation Wrapper Audit:**

Initial execution of setup verification failed due to missing CLI wrapper utilities:

- **Command use:** `sudo gvm-check-setup`
- **Output:** `sudo: gvm-check-setup: command not found`

```
(red@Kali)-[~]  
$ sudo gvm-check-setup  
sudo: gvm-check-setup: command not found
```

Initial failure indicating missing meta-package wrapper binaries.

- **Component Auditing:**

- **Command use:** `which openvas gvm gvmmd apt list --installed | grep -iE "gvm|openvas"`
- **Audit Findings:** identified that backend binaries (openvas-scanner 23.45.1, gvmmd 26.24.0, ospd-openvas 22.10.0, postgresql-18-pg-gvm 22.6.15) were present, but the parent gvm metapackage and helper utilities were missing.

```
(red@Kali)-[~]  
$ apt list --installed | grep -iE "gvm|openvas"  
  
WARNING: apt does not have a stable CLI interface. Use with caution in scripts.  
  
gvm-common/kali-rolling,now 26.24.0-1 all [installed,automatic]  
gvm/kali-rolling,now 26.24.0-1 amd64 [installed,automatic]  
libgvm22t64/kali-rolling,now 22.41.0-1 amd64 [installed,automatic]  
openvas-scanner/kali-rolling,now 23.45.1-1 amd64 [installed,automatic]  
ospd-openvas/kali-rolling,now 22.10.0-1 all [installed,automatic]  
postgresql-18-pg-gvm/kali-rolling,now 22.6.15-1 amd64 [installed,automatic]  
python3-gvm/kali-rolling,now 26.11.0-1 all [installed,automatic]  
  
—(red@Kali)-[~]
```

Verification of installed sub-packages and missing binary wrappers.

2.1.3 Package Deployment & Binary Confirmation

- **Installing the GVM Metapackage:**

- **Command use :** `sudo apt update && sudo apt install -y gvm`
- **Execution Detail:** Configured greenbone-security-assistant (26.17.0), gsad (24.16.0), and gvm-tools (25.4.6).


```
(red@Kali)-[~]
$ sudo runuser -u gvm -- gvm-manage-certs -a -f
Generated private key in /tmp/tmp.wL4gKqrlFs/cakey.pem.
Generated self signed certificate in /tmp/tmp.wL4gKqrlFs/cacert.pem.
Installed private key to /var/lib/gvm/private/CA/cakey.pem.
Installed certificate to /var/lib/gvm/CA/cacert.pem.
Generated private key in /tmp/tmp.wL4gKqrlFs/serverkey.pem.
Generated certificate request in /tmp/tmp.wL4gKqrlFs/serverrequest.pem.
Signed certificate request in /tmp/tmp.wL4gKqrlFs/serverrequest.pem with CA certificate in /var/lib/gvm/CA/cacert.pem to generate certificate in /tmp/tmp.wL4gKqrlFs/servercert.pem
Installed private key to /var/lib/gvm/private/CA/serverkey.pem.
Installed certificate to /var/lib/gvm/CA/servercert.pem.
Generated private key in /tmp/tmp.wL4gKqrlFs/clientkey.pem.
Generated certificate request in /tmp/tmp.wL4gKqrlFs/clientrequest.pem.
Signed certificate request in /tmp/tmp.wL4gKqrlFs/clientrequest.pem with CA certificate in /var/lib/gvm/CA/cacert.pem to generate certificate in /tmp/tmp.wL4gKqrlFs/clientcert.pem
Installed private key to /var/lib/gvm/private/CA/clientkey.pem.
Installed certificate to /var/lib/gvm/CA/clientcert.pem.
Removing temporary directory /tmp/tmp.wL4gKqrlFs.
```

Successful generation and installation of GVM CA, server, and client certificates.

- **NVT Collection Diagnostic Check:**

Running diagnostics confirmed valid server CA certificates, but reported missing NVT collection signatures:

- **Command use:** `sudo gvm-check-setup`
- **ERROR:** Directories containing the NVT collection not found.
- **FIX:** Run the NVT synchronization script `greenbone-feed-sync`.

```
(red@Kali)-[~]
$ sudo gvm-check-setup
gvm-check-setup 25.04.0
This script is provided and maintained by Debian and Kali.
Test completeness and readiness of GVM-25.04.0
Step 1: Checking OpenVAS (Scanner) ...
OK: OpenVAS Scanner is present in version 23.45.1.
OK: Notus Scanner is present in version 22.7.2.
OK: Server CA Certificate is present as /var/lib/gvm/CA/servercert.pem.
Checking permissions of /var/lib/openvas/gnupg/*
OK: _gvm owns all files in /var/lib/openvas/gnupg
OK: redis-server is present.
OK: scanner (db_address setting) is configured properly using the redis-server socket: /var/run/redis-openvas/redis-server.sock
OK: the mqtt_server_uri is defined in /etc/openvas/openvas.conf
ERROR: Directories containing the NVT collection not found.
FIX: Run the NVT synchronization script greenbone-feed-sync.
    sudo greenbone-feed-sync --type nvt

ERROR: Your GVM-25.04.0 installation is not yet complete!

Please follow the instructions marked with FIX above and run this
script again.

IMPORTANT NOTE: this script is provided and maintained by Debian and Kali.
If you find any issue in this script, please report it directly to Debian or Kali
```

Setup check confirming CA validation and prompting for NVT feed synchronization.

2.1.5 Automated Setup, Collation Conflict & Feed Synchronization

- **Executing Automated Setup Script:**

- **Command use:** `sudo gvm-setup`
- **Observed state:** The routine started PostgreSQL, generated certificates, and flagged database collation mismatches between version 2.41 and 2.42.

```
(red@Kali)-[~]
$ sudo gvm-setup
This script is provided and maintained by Debian and Kali.
If you find any issue in this script, please report it directly to Debian or Kali

[>] Starting PostgreSQL service

[>] Creating GVM's certificate files

[>] Creating PostgreSQL database
WARNING: database "postgres" has a collation version mismatch
DETAIL: The database was created using collation version 2.41, but the operating system provides version 2.42.
HINT: Rebuild all objects in this database that use the default collation and run ALTER DATABASE postgres REFRESH

[*] Creating database user
WARNING: database "postgres" has a collation version mismatch
DETAIL: The database was created using collation version 2.41, but the operating system provides version 2.42.
```

Initial gvm-setup execution encountering PostgreSQL template collation version mismatch.

- **Feed Data Synchronization:**

The automated synchronization routine successfully acquired locks and downloaded feeds via rsync:

- Notus files and NASL routines from `feed.community.greenbone.net`
- SCAP vulnerability data and CERT-Bund advisories
- OpenVAS daemon data feeds (`gvmd`)

```
Running as root. Switching to user _gvm_ and group _gvm_.
Trying to acquire lock on /var/lib/openvas/feed-update.lock
Acquired lock on /var/lib/openvas/feed-update.lock
+ Downloading Notus files from rsync://feed.community.greenbone.net/community/vulnerability-feed/24.10/vt-d
+ Downloading NASL files from rsync://feed.community.greenbone.net/community/vulnerability-feed/24.10/vt-da
Releasing lock on /var/lib/openvas/feed-update.lock

Trying to acquire lock on /var/lib/gvm/feed-update.lock
Acquired lock on /var/lib/gvm/feed-update.lock
+ Downloading SCAP data from rsync://feed.community.greenbone.net/community/vulnerability-feed/24.10/scap-d
+ Downloading CERT-Bund data from rsync://feed.community.greenbone.net/community/vulnerability-feed/24.10/c
+ Downloading gvmd data from rsync://feed.community.greenbone.net/community/data-feed/24.10/ to /var/lib/gv
Releasing lock on /var/lib/gvm/feed-update.lock

[*] Checking Default scanner
[*] Modifying Default Scanner

[+] Done
[i] Admin user already exists for GVM
[i] If you have forgotten it, you can change it. See gvmd manpage for more information

[>] You can now run gvm-check-setup to make sure everything is correctly configured
```

Terminal logs confirming synchronization of Notus, NASL, SCAP, CERT-Bund, and gvmd data.

- **PostgreSQL Missing Database Diagnostic:**

Diagnostics revealed that the gvmd database did not exist due to collation aborts during table creation:

- **Command use:** `sudo gvm-check-setup`
- **Step 5:** Checking PostgreSQL DB and user ...
- **ERROR:** The Postgresql DB does not exist.
- **FIX:** Run '`sudo runuser -u postgres -- /usr/share/gvm/create-postgresql-database`'

```

[red@Kali] (~)
$ sudo gvm-check-setup
gvm-check-setup 25.04.0
This script is provided and maintained by Debian and Kali.
Test completeness and readiness of GVM-25.04.0
Step 1: Checking OpenVAS (Scanner)...
OK: OpenVAS Scanner is present in version 23.45.1.
OK: Notus Scanner is present in version 22.7.2.
OK: Server CA certificate is present as /var/lib/gvm/CA/servercert.pem.
Checking permissions of /var/lib/openvas/gnupg/...
OK: _gvm owns all files in /var/lib/openvas/gnupg
OK: redis-server is present.
OK: scanner (db_address setting) is configured properly using the redis-server socket: /var/run/redis-openvas/redis-server.sock
OK: the mqtt_server_uri is defined in /etc/openvas/openvas.conf
OK: _gvm owns all files in /var/lib/openvas/plugins
OK: NVT collection in /var/lib/openvas/plugins contains 95102 NVTs.
OK: The notus directory /var/lib/notus/products contains 526 NVTs.
Checking that the obsolete redis database has been removed
Could not connect to Redis at /var/run/redis-openvas/redis-server.sock: No such file or directory
OK: No old Redis DB
Starting osdp-openvas service
Waiting for osdp-openvas service
OK: osdp-openvas service is active.
OK: osdp-OpenVAS is present in version 22.10.0.
Step 2: Checking GVM Manager ...
OK: GVM Manager (gvm) is present in version 26.24.0.
Step 3: Checking Certificates ...
OK: GVM client certificate is valid and present as /var/lib/gvm/CA/clientcert.pem.
OK: Your GVM certificate infrastructure passed validation.
Step 4: Checking data ...
OK: SCAP data found in /var/lib/gvm/scap-data.
OK: CERT data found in /var/lib/gvm/cert-data.
Step 5: Checking PostgreSQL DB and user ...
OK: PostgreSQL version and default port are OK.
WARNING: database "postgres" has a collation version mismatch
DETAIL: The database was created using collation version 2.41, but the operating system provides version 2.42.
HINT: Rebuild all objects in this database that use the default collation and run ALTER DATABASE postgres REFRESH COLLATION VERSION, or build PostgreSQL with the right library version.
ERROR: The PostgreSQL DB does not exist.
      FIX: Run 'sudo runuser -u postgres -- /usr/share/gvm/create-postgresql-database'

ERROR: Your GVM-25.04.0 installation is not yet complete!

Please follow the instructions marked with FIX above and run this
script again.

IMPORTANT NOTE: this script is provided and maintained by Debian and Kali.
If you find any issue in this script, please report it directly to Debian or Kali

```

Setup check verifying 95,102 NVTs indexed, but identifying missing gvmdb database schema.

- **Manual Database Creation Diagnostic Failure:**

Attempting manual database creation failed because template template1 possessed a collation mismatch:

- **Command use:** `sudo runuser -u postgres -- /usr/share/gvm/create-postgresql-database`
- **createdb: error:** database creation failed: ERROR: template database "template1" has a collation version mismatch

```

[red@Kali] (~)
$ sudo runuser -u postgres -- /usr/share/gvm/create-postgresql-database
WARNING: database "postgres" has a collation version mismatch
DETAIL: The database was created using collation version 2.41, but the operating system provides version 2.42.
HINT: Rebuild all objects in this database that use the default collation and run ALTER DATABASE postgres REFRESH COLLATION VERSION, or build PostgreSQL with the right library version.
[!] User gvm already exists in PostgreSQL
WARNING: database "postgres" has a collation version mismatch
DETAIL: The database was created using collation version 2.41, but the operating system provides version 2.42.
HINT: Rebuild all objects in this database that use the default collation and run ALTER DATABASE postgres REFRESH COLLATION VERSION, or build PostgreSQL with the right library version.

[*] Creating database
WARNING: database "postgres" has a collation version mismatch
DETAIL: The database was created using collation version 2.41, but the operating system provides version 2.42.
HINT: Rebuild all objects in this database that use the default collation and run ALTER DATABASE postgres REFRESH COLLATION VERSION, or build PostgreSQL with the right library version.
createdb: error: database creation failed: ERROR: template database "template1" has a collation version mismatch
DETAIL: The template database was created using collation version 2.41, but the operating system provides version 2.42.
HINT: Rebuild all objects in the template database that use the default collation and run ALTER DATABASE template1 REFRESH COLLATION VERSION, or build PostgreSQL with the right library version.
WARNING: database "postgres" has a collation version mismatch
DETAIL: The database was created using collation version 2.41, but the operating system provides version 2.42.
HINT: Rebuild all objects in this database that use the default collation and run ALTER DATABASE postgres REFRESH COLLATION VERSION, or build PostgreSQL with the right library version.

[*] Creating permissions
psql: error: connection to server on socket "/var/run/postgresql/.s.PGSQL.5432" failed: FATAL: database "gvmdb" does not exist

[*] Applying permissions
psql: error: connection to server on socket "/var/run/postgresql/.s.PGSQL.5432" failed: FATAL: database "gvmdb" does not exist
psql: error: connection to server on socket "/var/run/postgresql/.s.PGSQL.5432" failed: FATAL: database "gvmdb" does not exist

[*] Creating extension uuid-oss
psql: error: connection to server on socket "/var/run/postgresql/.s.PGSQL.5432" failed: FATAL: database "gvmdb" does not exist
psql: error: connection to server on socket "/var/run/postgresql/.s.PGSQL.5432" failed: FATAL: database "gvmdb" does not exist

[*] Creating extension pgcrypto
psql: error: connection to server on socket "/var/run/postgresql/.s.PGSQL.5432" failed: FATAL: database "gvmdb" does not exist
psql: error: connection to server on socket "/var/run/postgresql/.s.PGSQL.5432" failed: FATAL: database "gvmdb" does not exist

[*] Creating extension pg-gvm
psql: error: connection to server on socket "/var/run/postgresql/.s.PGSQL.5432" failed: FATAL: database "gvmdb" does not exist

```

Terminal failure during database creation caused by unrefreshed collation versions in template1.

- **Remediating Database Collation Versions:**

Refreshed collation version directly inside PostgreSQL:

- **Command use:** `sudo -u postgres psql -c "ALTER DATABASE template1 REFRESH COLLATION VERSION;"`
`sudo -u postgres psql -c "ALTER DATABASE postgres REFRESH COLLATION VERSION;"`

```
(red@Kali)-[~]
$ sudo -u postgres psql -c "ALTER DATABASE template1 REFRESH COLLATION VERSION;"
WARNING: database "postgres" has a collation version mismatch
DETAIL: The database was created using collation version 2.41, but the operating system provides version 2.42.
HINT: Rebuild all objects in this database that use the default collation and run ALTER DATABASE postgres REFRESH COLLATION VERSION, or build PostgreSQL with the right library version.
NOTICE: changing version from 2.41 to 2.42
ALTER DATABASE

(red@Kali)-[~]
$ sudo -u postgres psql -c "ALTER DATABASE postgres REFRESH COLLATION VERSION;"
WARNING: database "postgres" has a collation version mismatch
DETAIL: The database was created using collation version 2.41, but the operating system provides version 2.42.
HINT: Rebuild all objects in this database that use the default collation and run ALTER DATABASE postgres REFRESH COLLATION VERSION, or build PostgreSQL with the right library version.
NOTICE: changing version from 2.41 to 2.42
ALTER DATABASE
```

Executing ALTER DATABASE queries to refresh template1 and postgres collation versions.

- **Successful Database Creation & Extension Deployment:**
 Re-Running the creation script successfully established the database, permissions, and extensions.
 - **Command use:** `sudo runuser -u postgres -- /usr/share/gvm/create-postgresql-database`
 - **Execution Detail:** Confirmed CREAT ROLE, GRANT ROLE, and deployed extensions: uuid-ossdp, pgcrypto, and pg-gvm.

```
(red@Kali)-[~]
$ sudo runuser -u postgres -- /usr/share/gvm/create-postgresql-database
[i] User _gvm already exists in PostgreSQL

[*] Creating database

[*] Creating permissions
CREATE ROLE

[*] Applying permissions
GRANT ROLE

[*] Creating extension uuid-ossdp
CREATE EXTENSION

[*] Creating extension pgcrypto
CREATE EXTENSION

[*] Creating extension pg-gvm
CREATE EXTENSION

(red@Kali)-[~]
$
```

Successful creation of the gvm database and deployment of required PostgreSQL extensions.

2.1.6 User Provisioning, Feed Ownership & Ingestion Monitoring

- **User Account Requirement Checks:**
 Running diagnostics confirmed the database was online, but reported that no administrative user existed:
 - **Command use:** `sudo gvm-check-setup`

- **Step 5:** Checking Postgresql DB and user ...
- **ERROR:** No users found. You need to create at least one user to log in.
- **FIX:** create a user by running 'sudo runuser -u _gvm -- gvm --create-user= --password='

```
(red@Kali)-[~]
$ sudo gvm-check-setup
gvm-check-setup 25.04.0
This script is provided and maintained by Debian and Kali.
Test completeness and readiness of GVM-25.04.0
Step 1: Checking OpenVAS (Scanner)...
OK: OpenVAS Scanner is present in version 23.45.1.
OK: Notus Scanner is present in version 22.7.2.
OK: Server CA Certificate is present as /var/lib/gvm/CA/servercert.pem.
Checking permissions of /var/lib/openvas/gnupg/*
OK: _gvm owns all files in /var/lib/openvas/gnupg
OK: redis-server is present.
OK: scanner (db_address setting) is configured properly using the redis-server socket: /var/run/redis-openvas/redis-server.sock
OK: the mqtt_server_uri is defined in /etc/openvas/openvas.conf
OK: _gvm owns all files in /var/lib/openvas/plugins
OK: NVT collection in /var/lib/openvas/plugins contains 95102 NVTs.
OK: The notus directory /var/lib/notus/products contains 526 NVTs.
Checking that the obsolete redis database has been removed
OK: No old Redis DB
OK: ospd-openvas service is active.
OK: ospd-OpenVAS is present in version 22.10.0.
Step 2: Checking GVM Manager ...
OK: GVM Manager (gvm) is present in version 26.24.0.
Step 3: Checking Certificates ...
OK: GVM client certificate is valid and present as /var/lib/gvm/CA/clientcert.pem.
OK: Your GVM certificate infrastructure passed validation.
Step 4: Checking data ...
OK: SCAP data found in /var/lib/gvm/scap-data.
OK: CERT data found in /var/lib/gvm/cert-data.
Step 5: Checking Postgresql DB and user ...
OK: Postgresql version and default port are OK.
gvm | _gvm | UTF8 | libc | en_IN | en_IN |
16441pg-gvm|10|2200|f|22.6||
ERROR: No users found. You need to create at least one user to log in.
FIX: create a user by running 'sudo runuser -u _gvm -- gvm --create-user=<name> --password=<password>'

ERROR: Your GVM-25.04.0 installation is not yet complete!

Please follow the instructions marked with FIX above and run this
script again.

IMPORTANT NOTE: this script is provided and maintained by Debian and Kali.
If you find any issue in this script, please report it directly to Debian or Kali
```

Diagnostic check verifying database readiness and prompting for administrative user creation.

- **Provisioning Administrative Account & Validating Setup:**

Created the primary administrative account:

- **Command use:** `sudo runuser -u _gvm -- gvm --create-user=admin --password=admin && sudo gvm-check-setup`
- **Result:** Returned It seems like your GVM-25.04.0 installation is OK.

Confirming:

- OpenVAS Scanner Present (23.45.1).
- Notus Scanner present (22.7.2).
- Redis Unix Socket connection active (/var/run/redis-openvas/redis-server.sock).
- 95,102 active NVTs indexed.
- Background daemons active (gvms 26.24.0, gsad 24.16.0, ospd-openvas 22.10.0).

```
(red@Kali)-[~]
$ sudo runuser -u _gvm -- gvm --create-user=admin --password=admin
User created.

(red@Kali)-[~]
$ sudo gvm-check-setup
gvm-check-setup 25.04.0
This script is provided and maintained by Debian and Kali.
Test completeness and readiness of GVM-25.04.0
Step 1: Checking OpenVAS (Scanner) ...
OK: OpenVAS Scanner is present in version 23.45.1.
OK: Notus Scanner is present in version 22.7.2.
OK: Server CA Certificate is present as /var/lib/gvm/CA/servercert.pem.
Checking permissions of /var/lib/openvas/gnupg/*
OK: _gvm owns all files in /var/lib/openvas/gnupg
OK: redis-server is present.
OK: scanner (db_address setting) is configured properly using the redis-server socket: /var/run/redis-openvas/redis-server.sock
OK: the mqtt_server_uri is defined in /etc/openvas/openvas.conf
OK: _gvm owns all files in /var/lib/openvas/plugins
OK: NVT collection in /var/lib/openvas/plugins contains 95102 NVTs.
OK: The notus directory /var/lib/notus/products contains 526 NVTs.
Checking that the obsolete redis database has been removed
OK: No old Redis DB
OK: ospd-openvas service is active.
OK: ospd-OpenVAS is present in version 22.10.0.
Step 2: Checking GVM Manager ...
OK: GVM Manager (gvm) is present in version 26.24.0.
Step 3: Checking Certificates ...
OK: GVM client certificate is valid and present as /var/lib/gvm/CA/clientcert.pem.
OK: Your GVM certificate infrastructure passed validation.
Step 4: Checking data ...
OK: SCAP data found in /var/lib/gvm/scap-data.
OK: CERT data found in /var/lib/gvm/cert-data.
Step 5: Checking PostgreSQL DB and user ...
OK: PostgreSQL version and default port are OK.
gvm | _gvm | UTF8 | libc | en_IN | en_IN | | |
16441pg-gvm|0|2200|f|22.6||
OK: At least one user exists.
Step 6: Checking Greenbone Security Assistant (GSA) ...
(gsad:34622): GLib-CRITICAL **: 19:59:06.684: g_file_get_contents: assertion 'filename != NULL' failed
OK: Greenbone Security Assistant is present in version Deamon 24.16.0-git.
Step 7: Checking if GVM services are up and running ...
Starting gvm service
Waiting for gvm service
OK: gvm service is active.
Starting gsad service
Waiting for gsad service
OK: gsad service is active.
Step 8: Checking few other requirements...
OK: nmap is present.
OK: ssh-keygen found, LSC credential generation for GNU/Linux targets is likely to work.
OK: nsis found, LSC credential package generation for Microsoft Windows targets is likely to work.
OK: xsltproc found.
WARNING: Your password policy is empty.
SUGGEST: Edit the /etc/gvm/pwpolicy.conf file to set a password policy.
Step 9: Checking greenbone-security-assistant ...
OK: greenbone-security-assistant is installed

It seems like your GVM-25.04.0 installation is OK.
```

Complete health check confirming “It seems like your GVM-25.04.0 installation OK.”

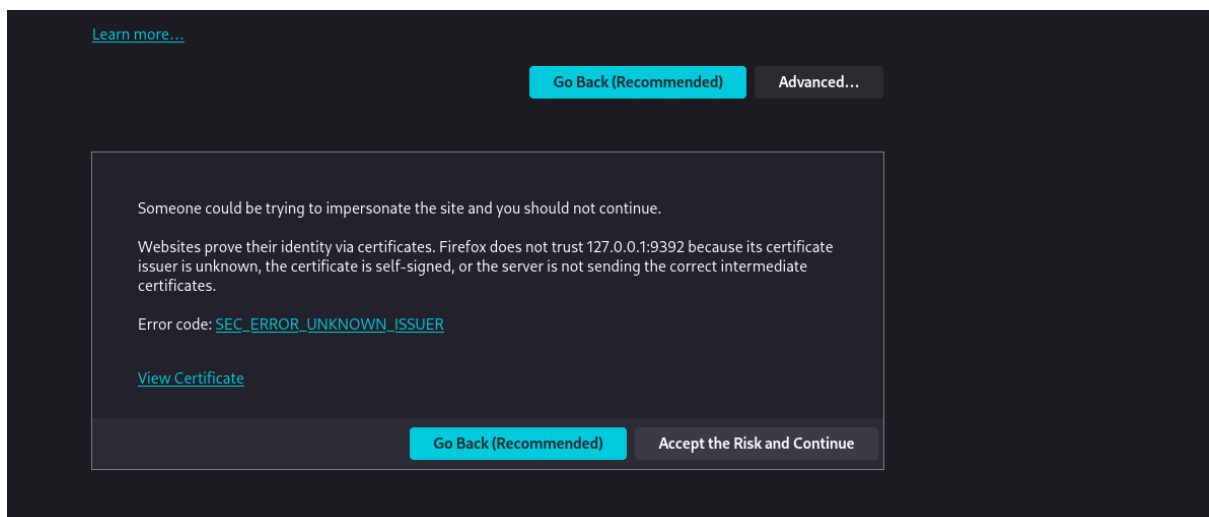
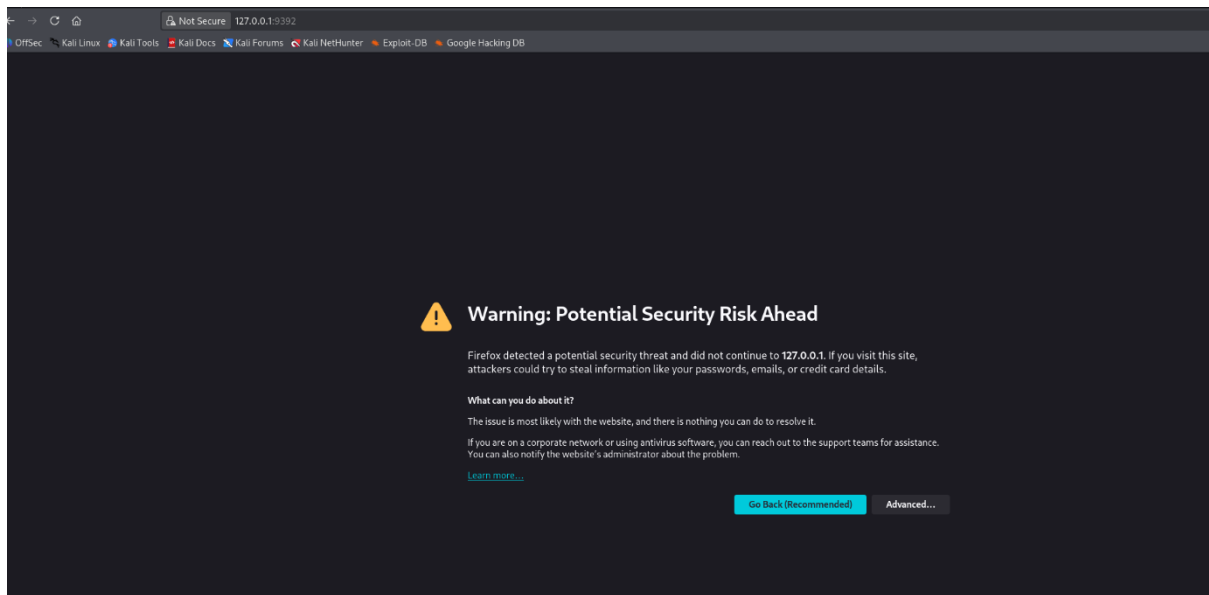
- **Starting Daemon Services:**
 - **Command use:** sudo gvm-start
 - **Result:** Confirmed GVM Services are already running

```
(red@Kali)-[~]
$ sudo gvm-start
[i] GVM services are already running
```

Output of sudo gvm-start verifying all backend GVM daemons are operational.

1. Web Browser Console Access & SSL Certification Acceptance:

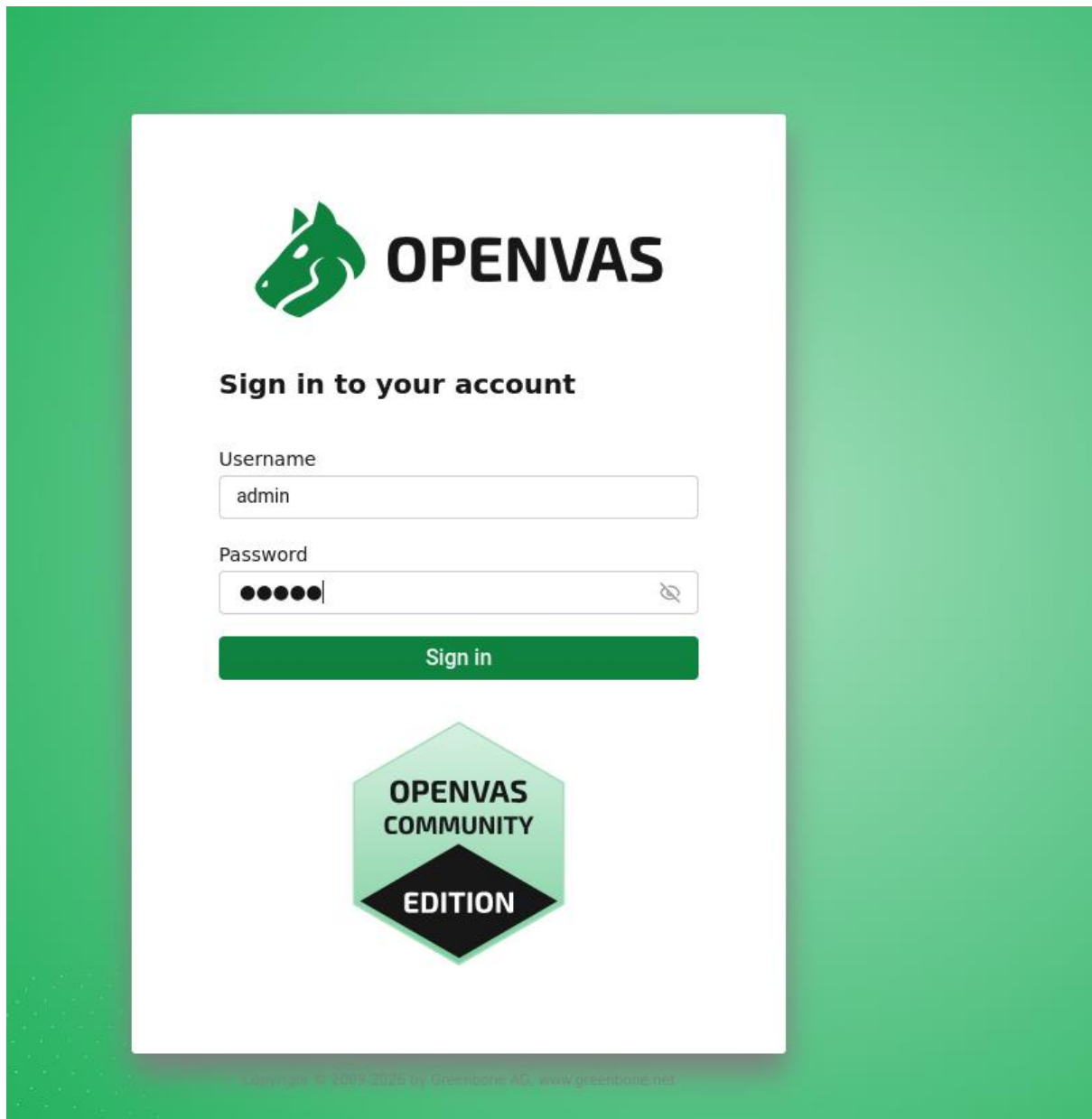
Navigated to (<https://127.0.0.1:9392>) in Firefox. The browser presented a self-signed certification warning (SEC_ERROR_UNKNOWN_ISSUER), which was confirmed and bypassed via Advanced-> Accept the Risk and Continue.



Handling Firefox self-signed TLS warning for Greenbone Security Assistance interface.

Greenbone Security Assistant Authentication:

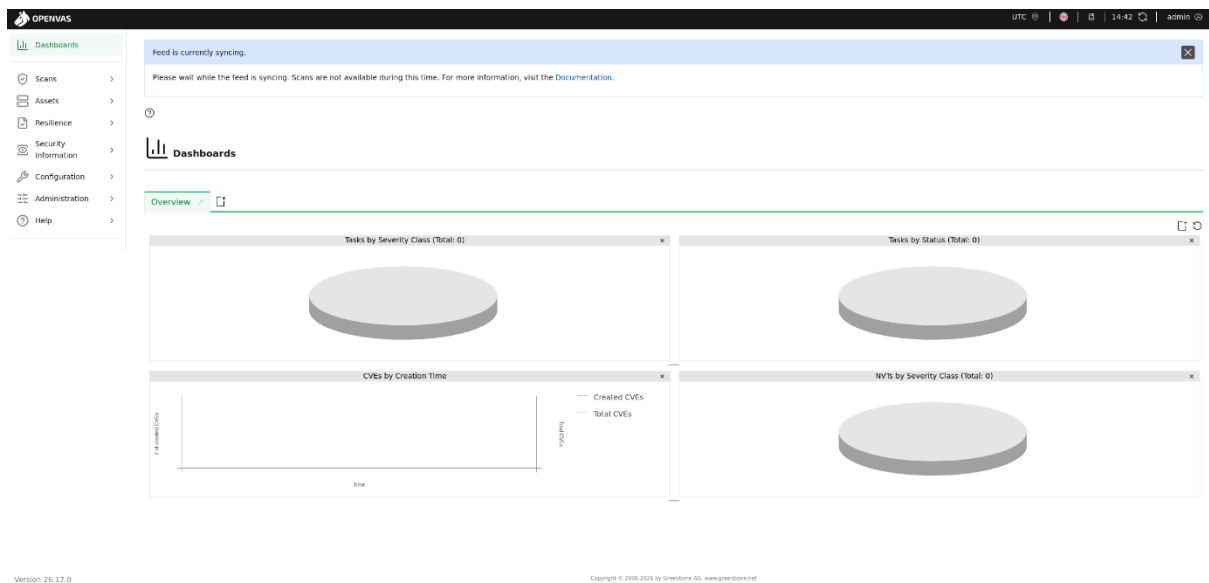
Authenticated to the GSA console using username admin and password admin.



OpenVAS community Edition login screen shot at (<https://127.0.0.1:9392>).

2. Feed Ingestion Monitoring:

The GSA dashboard initially presented a top status notification stating. “Feed is currently syncing. Please wait while the feed is syncing. Scans are not available during this time.”



GSA dashboard displaying blue banner indication background feed parsing and database ingestion.

3. Feed Status Interface Verification:

Audit synchronization progress via Administration-> Feed Status. The NVT feed was marked current (version 20260909T0553), while SCAP, CERT, and GVMOD_DATA displayed Update in progress..

Type	Content	Origin	Version	Status
NVT	NVTs	Greenbone Community Feed	20260909T0553	Current
SCAP	CVEs, CPEs	Greenbone SCAP Data Feed	20260909T0206	Update in progress...
CERT	CERT-Bund Advisories DFN-CERT Advisories	Greenbone CERT Data Feed	20260909T0428	Update in progress...
GVMOD_DATA	Compliance Policies Port Lists Report Formats Scan Configs	Greenbone Data Objects Feed	20260909T0513	Update in progress...

Feed Status page showing NVT feed current and relational SCAP/CERT feeds updating.

- **Retrieving User UUID & Binding Feed Ownership:**

Retrieved the administrative user UUID and mapped it to the internal feed owner setting 78eceaec-3385-11ea-b237-28d24461215b:

- `sudo runuser -u _gvm -- gvm --get-users --verbose`
- Output: admin 2b3af001-6dae-4f1c-b61a-006582758c4a
- `sudo runuser -u _gvm -- gvm --modify-setting 78eceaec-3385-11ea-b237-28d24461215b --value 2b3af001-6dae-4f1c-b61a-006582758c4a`

```
(red@Kali)-[~]
$ sudo runuser -u _gvm -- gvm --get-users --verbose
admin 2b3af001-6dae-4f1c-b61a-006582758c4a
```

Extraction of admin account UUID (2b3af001-6dae-4f1c-b61a-006582758c4a) via CLI.

2.2 Phase 2: Active Discovery & Fingerprinting (Active Reconnaissance)

Active reconnaissance was conducted from the testing node (192.168.64.129) without per-authenticated credentials:

- **Subnet Discovery Sweep:**

Swept the private segment using ARP/ICMP frame requests:

- **Command use:** `sudo nmap -sn 192.168.64.0/24`
- **Execution Details:** Discovered 6 active hosts on the subnet in 3.77 seconds, confirming candidate operational endpoints at 192.168.64.130 (MAC 00:0C:29:13:BA:B7) and 192.168.64.133 (MAC 00:0C:29:5F:D7:36).

```
(red@Kali)-[~]
$ sudo nmap -sS -O -F 192.168.64.130 192.168.64.133
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-09 21:39 +0530
Nmap scan report for 192.168.64.130
Host is up (0.0010s latency).
Not shown: 99 filtered tcp ports (no-response)
PORT      STATE SERVICE
5357/tcp  open  wsddapi
MAC Address: 00:0C:29:13:BA:B7 (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running (JUST GUESSING): Microsoft Windows 2022|11|2016 (92%)
OS CPE: cpe:/o:microsoft:windows_server_2022 cpe:/o:microsoft:windows_11 cpe:/o:microsoft:windows_server_2016
Aggressive OS guesses: Microsoft Windows Server 2022 (92%), Microsoft Windows 11 21H2 (85%), Microsoft Windows Server 2016 (85%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

Nmap scan report for 192.168.64.133
Host is up (0.00043s latency).
Not shown: 82 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
513/tcp   open  login
514/tcp   open  shell
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
8009/tcp  open  ajp13
MAC Address: 00:0C:29:5F:D7:36 (VMware)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop

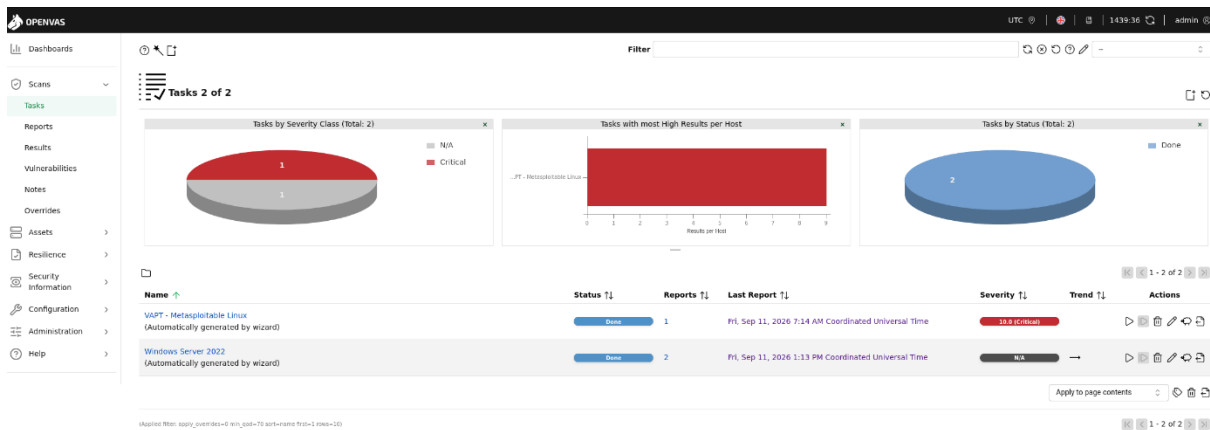
OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 2 IP addresses (2 hosts up) scanned in 17.24 seconds
```

Nmap OS and service banner fingerprinting terminal output distinguishing both targets.

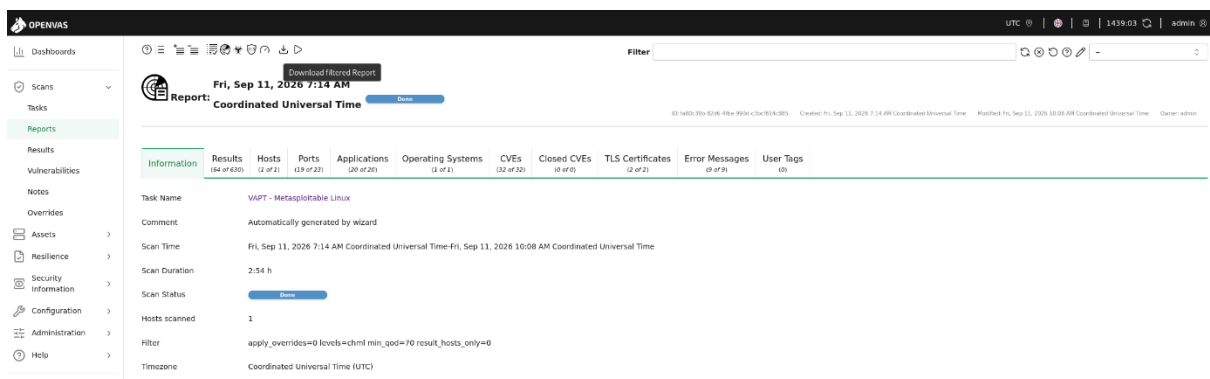
2.3 Phase 3: Vulnerability Analysis & Scanning

Automated vulnerability scanning was executed using Greenbone Vulnerability Management (GVM 25.04.0) under the "Full and Fast" profile:

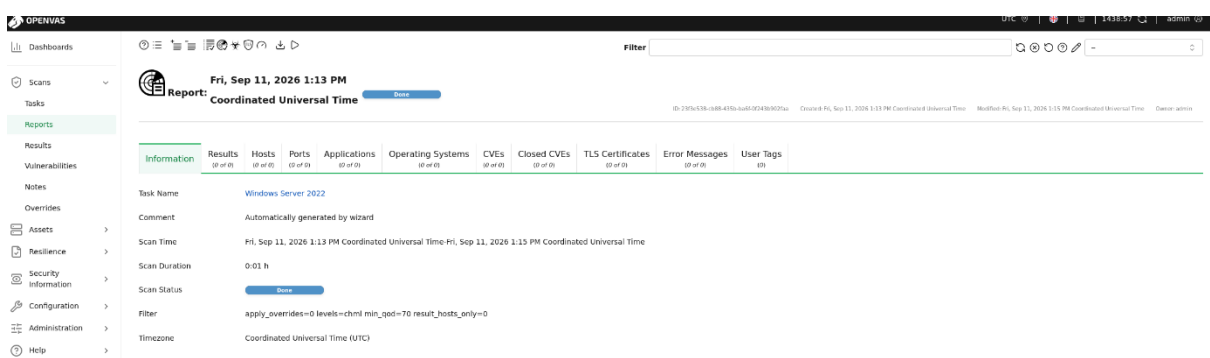
- **Metasploitable Linux Task:** Executed between 07:14:48 UTC and 10:08:55 UTC (duration: 2h 54m), executing active vulnerability checks across all exposed listening daemons and identifying 64 filtered findings.
- **Windows Server 2022 Task:** Executed between 13:13:51 UTC and 13:15:37 UTC (duration: 0h 01m), evaluating the unauthenticated external perimeter.



GSA Tasks Dashboard (Tasks 2 of 2) confirming completion of both scans: VAPT - Metasploitable Linux (Severity: 10.0 Critical) and Windows Server 2022 (Severity: N/A)



OpenVAS Report Overview for VAPT - Metasploitable Linux confirming Scan Duration 2:54 h, 64 of 630 results filtered, 19 open ports, 20 applications, and 32 CVEs.



OpenVAS Report Overview for Windows Server 2022 confirming Scan Duration 0:01 h, 0 of 0 results detected due to external perimeter firewall filtering.

Section 3: EXECUTIVE SUMMARY & COMPARATIVE POSTURE MATRIX

3.1 Overall Security Posture Evaluation

The automated assessment revealed an extreme disparity in perimeter security and host hardening:

- **Metasploitable Linux (192.168.64.133)**: Presents a CRITICAL overall risk posture (Severity 10.0). Over 20 legacy network Daemons are exposed without perimeter filtering. The host harbours historic, publicly weaponized vulnerabilities- including unauthenticated remote backdoor access, unencrypted administrative shells, and cleartext database listeners.
- **Microsoft Windows Server 2022 (192.168.64.130)**: Presents a SECURE/HARDENED PERIMETER (Severity N/A). The default host-based firewall dropped unsolicited connection attempts and suppressed ICMP echo probes, resulting in Zero actionable remote exposures under black-box scanning.

3.2 Quantitative Vulnerability Breakdown

Assessment Dimension	Metasploitable Linux (192.168.64.133)	Windows Server 2022 (192.168.64.130)
Operating System	Ubuntu Linux 8.04 (Kernel 2.6.24)	Microsoft Windows 2022 (192.168.64.130)
Scan Execution Duration	2 Hours 54 Minutes	0 Hours 01 Minute
Total Unfiltered Scan Detections	630 Total Detections	0 Total Detections
Total Actionable Findings (QoD >= 70%)	64 Actionable Vulnerabilities	0 Remote Exposures
Critical Severity (CVSS 9.0 – 10.0)	12 Findings	0 Finding
High Severity (CVSS 7.0 – 8.9)	9 Findings	0 Findings
Medium Severity (CVSS 4.0 – 6.9)	37 Findings	0 Findings
Low Severity (CVSS 0.1 – 3.9)	6 Findings	0 Findings
Identified Open Ports	19 Distinct Ports Reported	0 Unfiltered Ports Reported
Associated CVE Count	32 Unique CVEs Reported	0 CVEs Discovered
Overall Perimeter Posture	Extremely Vulnerable / Compromised	Hardened / Fully Filtered

1 Result Overview

Host	Critical	High	Medium	Low	Log	False P.
192.168.64.133	12	9	37	6	0	0
Total: 1	12	9	37	6	0	0

Vendor security updates are not trusted.

Overrides are off. Even when a result has an override, this report uses the actual threat of the result.

Information on overrides is included in the report.

Notes are included in the report.

This report might not show details of all issues that were found.

Issues with the threat level "Log" are not shown.

Issues with the threat level "Debug" are not shown.

Issues with the threat level "False Positive" are not shown.

Only results with a minimum QoD of 70 are shown.

This report contains all 64 results selected by the filtering described above. Before filtering there were 630 results.

1.1 Host Authentications

Host	Protocol	Result	Port/User
192.168.64.133	SMB	Success	Protocol SMB, Port 445, User

2 Results per Host

2.1 192.168.64.133

Host scan start Fri Sep 11 07:16:08 2026 UTC
Host scan end Fri Sep 11 10:08:51 2026 UTC

Service (Port)	Threat Level
6200/tcp	Critical
5900/tcp	Critical
3632/tcp	Critical
8787/tcp	Critical
3306/tcp	Critical
general/tcp	Critical
513/tcp	Critical
5432/tcp	Critical
80/tcp	Critical
512/tcp	Critical
21/tcp	Critical
1524/tcp	Critical
1099/tcp	High
6697/tcp	High
2121/tcp	High
513/tcp	High
5432/tcp	High
80/tcp	High
514/tcp	High
21/tcp	High
5900/tcp	Medium
22/tcp	Medium
2121/tcp	Medium
5432/tcp	Medium
80/tcp	Medium
23/tcp	Medium

... (continues) ...

Page 3 of OpenVAS Metasploitable PDF report showing the 64 vulnerability Distribution chart (12 Critical, 9 High, 37 Medium, 6 Low).

SECTION 4: TECHNICAL VULNERABILITY FINDINGS DEEP DIVE

4.1 Target Node 1: Metasploitable Linux (192.168.64.133)

Finding L-01: Vsftpd 2.3.4 Compromised Source Package Backdoor

- Vulnerability Identifier: CVE-2011-2523 (NVT OID: 1.3.6.1.4.1.25623.1.0.103185)
- CVSS v3.1 Score: 9.8 (Critical)

- Affected Ports/Services: 21/TCP (FTP), 6200/TCP (Backdoor Shell)
- Quality of Detection (QoD): 99%
- Technical Summary: The installed vsftpd-2.3.4 daemon contains an embedded malicious backdoor within its source archive. Supplying a username ending with a smiley sequence :) triggers the daemon to spawn an unauthenticated root bind shell listening on port 6200/TCP.
- Observed Evidence: OpenVAS actively verified the presence of the interactive root listener responding directly on port 6200/TCP.
- Impact: Immediate unauthenticated remote root shell access, allowing complete control over host resources.
- Remediation: Purge the vulnerable package (apt-get purge vsftpd) and enforce OpenSSH Sftp using key-based authentication.

Finding L-02: Ingreslock Interactive Shell Backdoor

- Vulnerability Identifier: CWE-284 (NVT OID: 1.3.6.1.4.1.25623.1.0.103549)
- CVSS v3.1 score: 10.0 (Critical)
- Affected Ports/Services: 1524/TCP (ingreslock)
- Quality of Detection (QoD): 99%
- Technical Summary: A legacy backdoor service is attached to TCP port 1524, providing direct root shell access to connecting clients without authentication.
- Observed Evidence: OpenVAS dispatched the command id; to port 1524 and received output: uid=0(root) gid=0(root).
- Impact: Remote administrative system compromise with no credential requirement.
- Remediation: Terminate the rogue process and remove the service entry from /etc/inetd.conf .

Finding L-03: DistCC Distributed Compilation Daemon Remote Code Execution

- Vulnerability Identifier: CVE-2004-2687 (NVT OID: 1.3.6.1.4.1.25623.1.0.103553)
- CVSS v3.1 Score: 9.3 (Critical)
- Affected Ports/Services: 3632/TCP (distcc)
- Quality of Detection (QoD): 99%
- Technical Summary: The DistCC services fails to validate incoming compilation requests, allowing remote client to execute arbitrary system commands.
- Observed Evidence: The Scanner executed the command id over port 3632, returning: uid = 1 (daemon) gid = 1 (daemon)
- Impact: Unauthenticated remote command executed under Daemon privilege, serving as an initial vector for local privilege escalation.
- Remediation: Upgrade DistCC to a patched release and implement client IP whitelisting via firewall filter.

Finding L-04: Distributed Ruby (dRuby/DRb) Arbitrary Command execution

- Vulnerability Identifier: BID-47071 (NVT OID: 1.3.6.1.4.1.25623.1.0.108010)
- CVSS v3.1 Score: 10.0 (Critical)
- Affected Ports/Services: 8787/TCP (druby_timeserver)
- Quality of Detection (QoD): 99%
- Technical Summary: The Distributed Ruby runtime exposes remote objected methods without access control list, permitting remote callers to execute arbitrary system commands via syscall invocations.
- Observed Evidence: Injected syscalls returned server traceback from /usr/lib/ruby/1.8/drbb.rb:1555 confirming execution.
- Impact: Remote code execution within the execution context of Ruby service.
- Remediation: Bind DRb daemons exclusively to 127.0.0.1 and enforce access rule via drbb/acl.rb .

Finding L-05: Relational Database Superuser Default Credentials

- Vulnerability Identifier: CVE-2001-0645 (MySQL), CWE-287
- CVVs v3.1 Score: 9.8 (MySQL) and 9.0 (PostgreSQL)
- Affected Ports / Services: 3306/TCP (MySQL), 5432/TCP (PostgreSQL)
- Quality of Detection (QoD): 95% – 99%
- Technical Summary: Both database listeners are exposed to the network using default administrative credentials without authentication requirements.
- Observed Evidence:
 - MySQL: Logged in successfully as root with an empty password.
 - PostgreSQL: Logged in successfully as user postgres with password postgres
- Impact: Direct access to databases, intellectual property exposure, and remote shell escalation via database functions
- Remediation: Bind databases to loopback (127.0.0.1) and enforce strong, non-default passwords.

Finding L-06: Unauthenticated Legacy Berkeley R-Services

- Vulnerability Identifier: CVE-1999-0651 (rlogin), CVE-1999-0618 (rexec)
- CVVs v3.1 Score: 10.0 (Critical)
- Affected Ports / Services: 512/TCP (rexec), 513/TCP (rlogin), 514/TCP (rsh)
- Quality of Detection (QoD): 80%

- Technical Summary: Berkeley r-commands transmit session traffic in cleartext and allow unauthenticated root login based on source addressing.
- Observed Evidence: OpenVAS established a passwordless root session across port 513.
- Impact: Complete remote root takeover without credentials.
- Remediation: Disable inetd r-service sockets (systemctl disable inetd) and enforce SSHv2.

Finding L-07: Samba MS-RPC Remote Shell Command Execution

- Vulnerability Identifier: CVE-2007-2447 (NVT OID: 1.3.6.1.4.1.25623.1.0.108011)
- CVVs v3.1 Score: 8.0 (High)
- Affected Ports / Services: 139/TCP, 445/TCP (Samba 3.0.20)
- Quality of Detection (QoD): 99%
- Technical Summary: Samba 3.0.20 fails to properly escape input in its username map script configuration, allowing shell commands to be injected into MS-RPC request.
- Observed Evidence: Injected MS-RPC parameters prompted the server to dispatch ICMP packets containing OpenVASVT59931 back to the scanner
- Impact: Remote command execution under root privileges
- Remediation: Upgrade Samba to modern supported version (v3.0.25+ or current stable branch)

Finding L-08: Multi-Protocol Default Credentials (FTP & VNC)

- Vulnerability Identifier: CVE-1999-0501 (FTP), CWE-521
- CVVs v3.1 Score: 7.5 (High) – 9.0 (Critical)
- Affected Ports / Services: 21/TCP, 2121/TCP (FTP), 5900/TCP (VNC)
- Quality of Detection (QoD): 70% - 95%
- Technical Summary: Discovered services accept trivial and well-know default passwords.
- Observed Evidence:
 - VNC port 5900 authenticated with password: password

- ProFTPD port 2121 authenticated with credentials:
msfadmin:msfadmin , postgres:postgres, user:user
- Impact: Unauthorized interactive graphical desktop access and unrestricted file modification.
- Remediation: Enforce strong password complexity rules, multi-factor authentication, or session encapsulation over SSH.

4.2 Target Node 2: Microsoft Windows Server 2022 (192.168.64.130)

Finding W-01: Perimeter Firewall Suppression & Host Hardening Evaluation

- Vulnerability Metric: 0 Remote Vulnerabilities identified.
- CVSS v3.1 Score: 0.0 (Informational / Hardened)
- Affected Ports/Services: Network Layer (ICMP/TCP)
- Technical Analysis: Windows Defender Firewall operates in a default-drop state for unsolicited incoming probes. The host dropped standard ICMP echo requests, causing the default scanner alive test to mark the host as inactive. (Total: 0 Findings).
- Security Posture Takeaway: The operating system demonstrates effective perimeter resilience against unauthenticated, opportunistic scanning sweeps.
- Internal Risk Note: While perimeter firewall rules are effective externally, internal services (such as SMB signing enforcement on port 445) require credentialed assessment to ensure defense-in-depth against lateral movement.

SECTION 5: STRATEGIC REMEDIATION ROADMAP (NIST SP 800-115)

Remediation milestones are prioritized across three chronological execution tiers based on exploitability, operational exposure, and CVSS v3.1 severity impact:

5.1 Tier 1: Immediate Containment (0 – 48 Hours)

- **Backdoor Decommissioning:** Immediately kill and purge backdoored packages (vsftpd-2.3.4, UnrealIRCd). Remove rogue root listeners from /etc/inetd.conf (Ingreslock/1524).
- **Cleartext Protocol Retirement:** Disable rlogin, rexec, rsh, and telnet daemons. Transition administrative sessions to OpenSSH using cryptographic public keys.
- **Default Credential Remediation:** Configure non-blank, complex passwords for database superuser accounts (root on MySQL, postgres on PostgreSQL) and restrict listening bindings to 127.0.0.1.

5.2 Tier 2: System Hardening & Isolation (1 – 2 Weeks)

- **Remote Execution Daemon Hardening:** Apply IP-level access controls or terminate unauthenticated compile/execution tools (distcc and druby)
- **Obsolete Asset Migration:** Plan migration for obsolete operating systems. Ubuntu 8.04 reached official End-of-Life on May 9, 2013, and lacks vendor security patches.
- **Internal Windows Auditing:** Establish credentialed SMB/RPC auditing accounts to evaluate internal Windows configurations (such as SMB signing and cumulative patch compliance) behind the firewall perimeter.

5.3 Tier 3: Governance & Verification (Ongoing)

- **Continuous Vulnerability Assessment:** Schedule monthly authenticated scans using GVM/OpenVAS to detect regressions and configuration drift.
- **Network Micro-segmentation:** Isolate legacy application tiers from production infrastructure using VLANs and stateful firewall boundaries to limit blast radiuses.

SECTION 6: CONCLUSION & ASSESSMENT SIGN-OFF

6.1 Final Risk Summary

The NIST SP 800-115 assessment established a clear divergence in operational security posture:

- **Metasploitable Linux (192.168.64.133):** Unacceptable security risk. With 12 Critical and 9 High vulnerabilities, the system allows immediate, unauthenticated root takeover through multiple independent entry points.
- **Microsoft Windows Server 2022 (192.168.64.130):** Strong external defensive posture. The default host-based firewall successfully blocked unsolicited reconnaissance and automated network scans.

6.2 Sign-off & Certification

- **Assessment Framework:** NIST Special Publication 800-115
- **Testing Standard:** Non-destructive Technical Assessment & Vulnerability Analysis
- **Lead Security Assessor:** Kamalpreet Singh
- **Artifact Commit Date:** September 11, 2026
- **Status:** Complete / Findings Documented & Remediation Prioritized